

Care Access Navigator - Day 4

Establish High-Level Architecture & Data Flow

HealthLine Regional Medical Center

IAM + GRC Healthcare Cybersecurity Capstone | Week 1: Planning

Organization	HealthLine Regional Medical Center (HRMC)	Day 4 Focus	Architecture & Data Flow
Environment	Simulated / Non-Production	Primary Tool	Lucidchart
Data Rule	Synthetic Data Only	Project Phase	Week 1: Planning

1. Day 4 Goal

Section overview: This section sets the purpose for Day 4: turn the planning work from the first three days into a simple visual view of the environment. The goal is to show how people, identity and access, applications, monitoring, governance, and reporting connect before any detailed configuration begins.

Objective: Establish the first high-level Lucidchart architecture for HRMC showing how workforce users connect to IAM, simulated healthcare applications, logging and SIEM monitoring, GRC activities, and management reporting. The architecture provides a shared visual blueprint before technical configuration begins.

Why this matters: A high-level architecture helps show where identities originate, where access decisions are made, which systems hold sensitive information, where logs are generated, how suspicious activity is monitored, and how evidence and risk information reach management.

In plain terms: Day 4 creates the map of the environment. Later days will configure and test the individual pieces shown on this map.

2. How Day 4 Builds on Days 1-3

Section overview: This section shows that the architecture is not being created from scratch. Day 1 defined the hospital, users, applications, and sensitive-data boundary; Day 2 defined the scope and requirements; and Day 3 established the risk and compliance foundation. Day 4 brings those decisions together into one visual blueprint so every layer in the diagram has a clear business and security reason.

Day	What Was Established	How It Feeds the Architecture
Day 1	Defined HRMC, departments, users, applications, business problem, and simulated ePHI boundary	Provides the people, systems, and sensitive-data context for the architecture
Day 2	Defined project objectives, scope, assumptions, and high-level requirements	Defines what the architecture must support
Day 3	Reviewed HIPAA/NIST concepts, risks, and preliminary control objectives	Defines why access, logging, monitoring, evidence, and oversight are needed
Day 4	Connect the previous planning work visually in one high-level architecture	Creates a shared blueprint for later IAM, SIEM, GRC, and reporting work

3. What a High-Level Architecture Means

Section overview: This section explains the level of detail expected in the first architecture. It focuses on the major components and how they interact, rather than technical details such as IP addresses, server settings, or firewall rules. This makes the diagram useful to both technical teams and non-technical stakeholders who need to understand the overall flow.

A high-level architecture is a simplified visual map of the major technology and governance layers. It does not show IP addresses, firewall rules, servers, database schemas, or detailed configuration. Instead, it shows the main components, how information moves between them, and where security and governance activities occur.

4. HRMC High-Level IAM + GRC Architecture

Section overview: This section presents the main visual blueprint for the Care Access Navigator environment. It shows the path from workforce users through IAM and applications, then into logging, SIEM monitoring, GRC activities, and management reporting. The diagram is intentionally high level so later project days can add configuration, controls, testing, and evidence without changing the overall design.

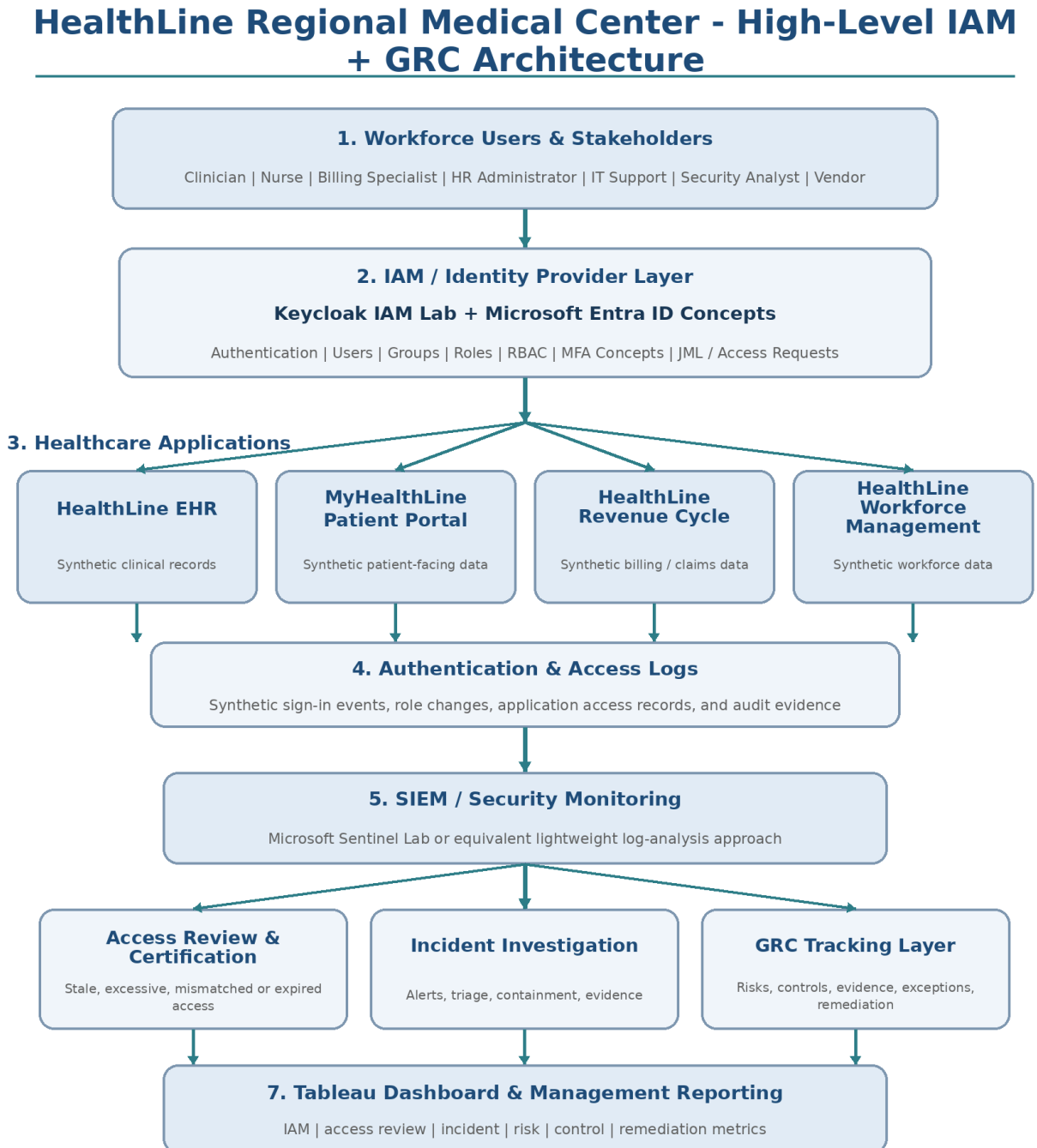


Figure 1. HRMC Day 4 High-Level IAM + GRC Architecture (reference layout for Lucidchart).

The flow starts with workforce identities, passes through the IAM layer for authentication and role-based access, reaches the simulated applications, produces authentication/access logs, and then feeds monitoring, access review, incident investigation, GRC tracking, and Tableau management reporting.

5. Layer-by-Layer Explanation

Section overview: This section breaks the architecture into clear layers and explains the purpose of each one. The analyst question in the table shows what an IAM/GRC analyst should think about at each layer, such as who needs access, how access is approved, what is monitored, and how evidence is reported. This helps connect technology components to business and security responsibilities.

Layer	Main Components	Purpose	Analyst Question
1. Users / Workforce	Clinician, Nurse, Billing, HR, IT Support, Security Analyst, Vendor	Represents the people or identities that need access	Who is the user, and what business role do they perform?
2. IAM / Identity Provider	Keycloak + Entra ID concepts; users, groups, roles, RBAC, MFA concepts	Authenticates identities and determines what access should be granted	How do we verify the user and assign the correct access?
3. Applications	HealthLine EHR, MyHealthLine Portal, Revenue Cycle, Workforce Management	Represents the systems users are trying to access	Which application and data does this role actually need?
4. Logs	Authentication and application access records	Creates evidence showing who signed in, what changed, and what was accessed	Can we reconstruct what happened?
5. SIEM / Monitoring	Microsoft Sentinel lab or equivalent lightweight analysis	Collects/reviews events and helps identify suspicious identity or access activity	What behavior should get the analyst's attention?
6. GRC / Investigation	Access review, incident investigation, risk/control/evidence/remediation tracking	Connects technical events to governance, risk, controls, and follow-up actions	What risk/control does this activity relate to, and what evidence do we keep?
7. Reporting	Tableau dashboard / management summary	Turns detailed security activity into understandable metrics and status	Can management understand the security posture without seeing unnecessary patient detail?

6. Example Data and Access Flow

Section overview: This section follows one user action from sign-in through access, logging, monitoring, investigation, and reporting. It demonstrates how IAM, SIEM, GRC, and reporting are connected parts of the same process rather than separate tools. A reader can use this flow to understand what happens behind a normal access request or security event from beginning to end.

Step	What Happens
1	A synthetic clinician attempts to sign in to HealthLine EHR.
2	Keycloak authenticates the identity and evaluates the user's group/role assignment.
3	RBAC allows only the permissions defined for the Clinician role.
4	The clinician opens a fictional patient record in the EHR.
5	The sign-in and access activity produce authentication/access logs.
6	The logs are reviewed by Microsoft Sentinel or the equivalent monitoring approach.
7	If the activity is unusual, a Security Analyst investigates; related risk/control/evidence is tracked in the GRC layer.
8	Aggregate IAM, incident, risk, control, and remediation metrics are summarized in Tableau for management.

Why this flow matters: It demonstrates traceability from a real business user action all the way to IAM enforcement, logging, monitoring, GRC evidence, and management reporting.

7. Security Boundaries and Design Notes

Section overview: This section identifies where sensitive simulated information exists and the security rules that should guide the architecture. It highlights the ePHI boundary, least privilege, separation of duties, vendor access, protected logs, and the use of synthetic data only. These notes help make sure the diagram reflects the project risks and compliance expectations established on Day 3.

Design Consideration	Day 4 Architecture Note
Simulated ePHI boundary	HealthLine EHR, MyHealthLine Patient Portal, HealthLine Revenue Cycle, and patient-level logs/evidence are treated as inside the simulated sensitive-data boundary.

Design Consideration	Day 4 Architecture Note
Workforce data	HealthLine Workforce Management contains synthetic employee information and is normally outside the patient ePHI boundary, but still requires appropriate access control.
Least privilege	Each role should receive only the permissions needed for its HRMC responsibilities.
Privileged / vendor access	Elevated or temporary access should be restricted, approved, time-limited, and reviewable.
Logging and evidence	Authentication/access events should be sufficient to support review, investigation, and future control testing.
Synthetic data rule	No real patient information, real ePHI, or production healthcare data is allowed in the project.

8. Lucidchart Build Guide

Section overview: This section turns the architecture idea into practical drawing guidance for Lucidchart. It defines the recommended layer order, shapes, arrows, labels, and page layout so the diagram stays consistent and easy to follow. The priority is clarity: a reviewer should be able to understand the main environment and data flow quickly without needing a technical explanation first.

Use the reference diagram in Section 4 as the first Lucidchart version. Keep the drawing simple and layered so a non-technical reviewer can understand it in under one minute.

Lucidchart Item	Recommended Day 4 Approach
Page layout	Portrait or landscape; use one page and center the flow from top to bottom.
Shapes	Use rounded rectangles for major layers and smaller rectangles for application/GRC subcomponents.
Layer order	Users → IAM → Applications → Logs → SIEM → Access Review / Incident / GRC → Reporting.
Connectors	Use directional arrows to show identity/access and log/event flow. Avoid crossing connectors where possible.
Labels	Use business-friendly names first (HealthLine EHR, Security Monitoring) and tool names second (Keycloak, Sentinel, Tableau).
Color use	Use the same dark blue / light blue palette as the Day 1-4 documentation for consistency.
Keep out of v1	Do not add firewalls, IP addresses, subnets, detailed APIs, ports, databases, or production infrastructure yet.

9. Key Terms

Section overview: This section provides short definitions for the main architecture and IAM/GRC terms used in the document. The purpose is to keep the language consistent and make the diagram understandable to people with different technical backgrounds. It is a quick reference, not a large glossary, so only terms directly needed for Day 4 are included.

Term	Plain-Language Meaning
Architecture layer	A group of related components that perform a similar purpose in the overall design.
Identity Provider (IdP)	The system that authenticates users and helps manage identities and access. Keycloak is the primary IdP lab in this project.
RBAC	Role-Based Access Control - permissions are assigned through job roles rather than one permission at a time.
SIEM	Security Information and Event Management - a platform/process used to collect and analyze security events and support detection/investigation.
Audit log	A record of an action such as sign-in, role change, or application access; it becomes evidence for review or investigation.
GRC layer	The project area where risks, controls, evidence, exceptions, remediation, and governance status are tracked.
Data flow	The path information or security events take between users, systems, monitoring, and reporting.

10. Day 4 Deliverables & Definition of Done

Section overview: This section converts the Day 4 work into specific, measurable outputs. It shows what should be completed, how much time is expected, and what “done” looks like before moving to the next project activity. It also makes clear that Day 4 is focused on architecture and documentation, not system configuration.

Deliverable	Output	Target Time	Done When
High-Level Architecture v1	Lucidchart diagram	45-60 min	All 7 layers are visible and connected clearly
Layer explanation	Architecture layer table	20 min	Each layer has a purpose and analyst question
Access/data-flow walkthrough	8-step scenario	15-20 min	A reader can follow one user action end-to-end

Deliverable	Output	Target Time	Done When
Boundary/design notes	Security boundary table	15 min	ePHI, least privilege, vendor/privileged, logging rules are clear
Evidence export	PNG/PDF screenshot of Lucidchart v1	10 min	Architecture artifact is saved for the Week 1 evidence folder